

# Verification Report

Security hardening pass — MCP for Unity

|            |                                                                                  |
|------------|----------------------------------------------------------------------------------|
| Subject    | Verify the hardening pass actually works (closes the gap the change doc flagged) |
| Branch     | verify/security — off beta, NOT merged (awaiting review)                         |
| Repository | skevin220/unity-mcp                                                              |
| Method     | Ran what could run; wrote missing tests; reported actual results                 |
| Date       | 2026-06-19                                                                       |

**Headline.** The **Python half is genuinely verified** — the full suite passes (1273) and the bridge-token resolver, off-loopback guard, and telemetry-off behaviours have executed positive+negative tests. The **security-critical C# was NOT executed**: this build environment has no Unity Editor and no C# compiler, so the compile, the EditMode tests, the live stdio-bridge gate, and the end-to-end pipeline are **BLOCKED here** and must be run on a Unity machine before this is “known-good.” **No fail-open was found** on any path that executed; that result does not yet extend to the unexecuted C# gates.

## Key findings

- **Environment blocker:** no Unity / Hub / dotnet / mono / csc on this machine. The brief assumed a Unity-equipped host; that assumption does not hold here.
- **Real regression caught & fixed:** running the full Python suite exposed 2 failures in test\_transport\_framing.py caused by the Task 2 token gate — the fake Unity servers never answered the new auth frame, so connect() failed closed. Fixed the fakes to ack the handshake (also exercises the positive token path).
- **11 new runnable security tests added and passing** (token resolver, off-loopback guard matrix, telemetry-off), each with a negative case.
- **C# EditMode tests written** for the dispatch boundary (R9) and play-mode gate (R6) — but not compiled/run here.
- **No fail-open** observed on executed paths; the unexecuted C# gates remain to be proven on Unity.

## Results — Parts A–D

| Item                                | Status  | Evidence                                                          |
|-------------------------------------|---------|-------------------------------------------------------------------|
| A · Editor compile (all versions)   | BLOCKED | No Unity / C# toolchain in this environment                       |
| B · Python suite (full)             | PASS    | 1273 passed, 3 skipped — after fixing 2 tests the hardening broke |
| B · C# EditMode suite               | BLOCKED | No Unity Editor                                                   |
| D · End-to-end pipeline (token set) | BLOCKED | Needs a live Editor + bridge                                      |

## Results — Part C (security behaviours)

| Item                                     | Status  | Evidence                                                            |
|------------------------------------------|---------|---------------------------------------------------------------------|
| C1 · token resolver (env / file / empty) | PASS    | 4 executed tests, both directions                                   |
| C1 · constant-time compare               | PASS    | Inspection: FixedTimeEquals / hmac.compare_digest; semantics tested |
| C1 · stdio bridge negative + hijack      | BLOCKED | C# in Unity; positive handshake exercised by framing tests          |
| C1 · HTTP /api/command + WS hub negative | PARTIAL | Gate confirmed by inspection (pre-session); no executed route test  |
| C2 · dispatch boundary (R9)              | PARTIAL | EditMode test written, not run                                      |
| C3 · Roslyn removal                      | PASS    | Tool dir deleted, zero refs; installer early-returns (inspection)   |
| C4 · execute_menu_item allow-list        | PARTIAL | Tests exist (Task 4), not run here                                  |
| C5 · play-mode gate                      | PARTIAL | EditMode negative test written, not run                             |
| C6 · off-loopback bind guard             | PASS    | 4 executed tests through real main(): full matrix                   |
| C7 · telemetry off                       | PASS    | 3 executed tests: default off, missing-config off, opt-in works     |
| C8 · server pin                          | PASS    | Inspection: resolves to mcpforunityserver==9.7.3                    |

**Legend.** PASS = executed and green. PARTIAL = code verified by inspection and/or a test written but not executed here. BLOCKED = cannot run in this environment (no Unity / compiler).

## What was actually run

- **Full Python suite:** `uv run pytest` → **1273 passed, 3 skipped** after the framing fix.
- **tests/test\_hardening\_security.py (new, 11 tests, all pass):** bridge-token resolver (env precedence, file fallback, empty→fail-closed, constant-time semantics); off-loopback guard driven through the real `main()` (loopback proceeds; 0.0.0.0 local + no token → `SystemExit 2`; 0.0.0.0 local + token proceeds; 0.0.0.0 remote-hosted proceeds); telemetry off by default + missing-config + opt-in.

## What was written but not executed (needs Unity)

- **ToolDiscoveryServiceTests (R9/R6):** non-core `execute_code` disabled by default; core `manage_scene` enabled; `execute_menu_item` disabled by default.
- **ManageEditorPlayGateTests (R6):** `manage_editor action=play` refused when `AllowPlayMode` is false, and does not enter play mode.
- **Caution:** these C# files match existing test patterns but were never compiled here — a name/API slip would only surface on a real compile. Treat the first Unity compile as the gate.

## What must be run on a Unity machine to close this out

- `tools/check-unity-versions.sh` — compile across the matrix, incl. `BridgeAuth` and the new `EditMode` tests (Part A).
- Unity Test Runner → `EditMode` (Part B-C#, and C2/C4/C5 execution).
- Live stdio-bridge negatives: connect to 127.0.0.1:6400 with no / wrong token → rejected; and the **hijack** test (an unauthenticated 2nd connection must not displace a live authenticated session). (C1)
- End-to-end with `UNITY_MCP_BRIDGE_TOKEN` set: spawn a `GameObject`, create/edit a script, run an `EditMode` test, read the console (Part D).

**Status & next step.** Work is on `verify/security`, pushed, **not merged to beta**. Open options: (a) leave for your review; (b) merge to beta now; (c) I can add an executed route-level test for the C1 HTTP `/api/command` negative case to upgrade that row from `PARTIAL` to `PASS`.